



Seguridad en Redes

Semana 4 · IDS/IPS a fondo · detección y prevención de intrusos · Snort y Security Groups AWS

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 4 · Periodo 2026-2 · Barranquilla, Colombia

Lo que ya dominas (semanas 1–3)

Semanas 1–2 · El mapa

Modelo TCP/IP y la capa donde vive cada control; NAT y routing; firewall, NGFW e IDS como conceptos diferenciados.

Semana 3 · El perímetro real

VLANs, subnetting y DMZ; firewall perimetral OPNsense configurado con reglas Zero Trust en el laboratorio.

Host · El filtro local

ufw sobre netfilter: política por defecto cerrada, reglas mínimas y verificación con nmap (open vs. filtered).

Hoy **no repetimos el firewall**: cambia la pregunta — de decidir **quién pasa** a observar **qué hace lo que ya pasó**.

SOLO PERÍMETRO

Una frontera dura hacia afuera y confianza total hacia adentro.

Basta un equipo comprometido — o un visitante malintencionado ya autenticado — para que el atacante se mueva con libertad interna.

PERÍMETRO + HOST

Cada servidor lleva su propio filtro: aunque el atacante cruce el perímetro, encuentra **puertos cerrados** en cada host que intenta tocar.

Captura la semana 3 aplicada máquina a máquina.

Esta sesión opera sobre Linux: **netfilter** es el mecanismo del kernel, **iptables** su interfaz clásica y **ufw** la capa simplificada — más IDS/IPS como detección complementaria al filtrado.

Por qué el firewall solo no alcanza

El firewall decide por reglas: **quién puede hablar**. Pero no examina **qué dice** un flujo que ya autorizó:

- Un ataque que viaja por el **puerto 443 permitido**, dentro de un túnel cifrado o con una **credencial válida**, cruza sin fricción.
- El **movimiento lateral** y la **exfiltración** ocurren después del acceso inicial: no hay conexión nueva que bloquear, hay **comportamiento que detectar**.
- Sin detección, el atacante puede semanas dentro; con detección hay **alerta temprana, visibilidad y evidencia forense**.

Idea central: el firewall es la puerta; el IDS/IPS es la videovigilancia que revisa lo que entró ya autenticado.

Tipo	Dónde vive	Qué observa	Modo
NIDS	Fuera de los hosts, escuchando una copia del tráfico (SPAN/TAP)	Paquetes y flujos de la red	Pasivo — detecta
HIDS	Dentro del sistema operativo del servidor	Logs, integridad de archivos, syscalls	Pasivo — detecta
NIPS	En línea, entre origen y destino	Cada paquete antes de entregarlo	Activo — bloquea
HIPS	Sobre el host o el servicio	Procesos y llamadas del propio equipo	Activo — bloquea
NBA / NDR	Análisis de flujos (NetFlow, telemetría)	Línea base de comportamiento y sus desvíos	Detecta anomalías

Lectura del nombre: **N/H** = dónde (red/host) · **D/P** = qué hace (detectar/prevenir).

IDS vs IPS: detectar y prevenir

IDS — detección pasiva



el ataque ya alcanzó el destino; la respuesta es posterior

IPS — prevención en línea



ambos trabajan con firmas (patrones conocidos) y anomalías (comportamiento inusual)

El firewall decide **por reglas** (quién puede hablar); el IDS/IPS decide **por contenido** (qué está diciendo) — capas complementarias, no sustituibles

Firmas vs. anomalías: dos formas de detectar

	Por firmas	Por anomalías
Cómo	Compara cada evento contra una base de patrones conocidos (como un antivirus de red)	Aprende una línea base del entorno y alerta los desvíos (volúmenes, horarios, destinos)
Fortaleza	Precisa, pocos falsos positivos, cada alerta es explicable	Puede descubrir lo desconocido: 0-days, uso interno abusivo
Debilidad	Ciega ante variantes nuevas hasta que existe la firma	Más falsos positivos; exige periodo de aprendizaje y ajuste fino

En producción se combinan: firmas para lo conocido, anomalías para lo desconocido — la base del NDR moderno (semana 13).

Anatomía de una regla Snort/Suricata

```
alert tcp any any -> $HOME_NET 80 (msg:"Posible escaneo HTTP"; flags:S; threshold:type threshold, track by_src, count 20, seconds 60; sid:1000001; rev:1;)
```

ACCIÓN

qué hacer si coincide: alert /
drop / reject / pass

PROTOCOLO

tcp / udp / icmp / ip / http
(app-layer)

ORIGEN / PUERTO

IP y puerto de origen del
tráfico a inspeccionar

DIRECCIÓN

-> unidireccional /
<> bidireccional

DESTINO / PUERTO

red/host y puerto de destino
(ej. \$HOME_NET 80)

OPCIONES (entre paréntesis)

msg: texto de la alerta · flags: banderas TCP a igualar
(S=SYN) · threshold: umbral para no saturar de alertas ·
sid/rev: identificador único y versión de la regla

Lectura de la regla de ejemplo: si llega tráfico TCP con bandera SYN hacia el puerto 80 de la red protegida, y esto ocurre 20+ veces en 60 s desde el mismo origen, generar una alerta (posible escaneo).

Cabecera (acción · protocolo · origen → destino) más opciones (msg, content, sid...): así se escribe toda la detección por firmas que usarás en el laboratorio.

- **Tres modos:** sniffer (-v), logger de paquetes (-l) y NIDS/NIPS (-c snort.conf) — el tercero es el operativo.
- **Reglas:** bases comunitaria y oficial de Cisco Talos (snort.org), actualizadas a diario; reglas locales propias para lo específico del entorno.
- **Modo inline:** con -Q --daq afpacket actúa como IPS y las acciones drop/reject bloquean de verdad.
- **Operación:** afinar falsos positivos con thresholds y suppressions — un IDS ruidoso termina ignorado.

```
[**] [1:1000001:1] ICMP test [**]  
[Priority: 0] 08-26 10:14:02.881342 10.0.2.15 -> 10.0.2.4  
ICMP TTL:64 TOS:0x0 ID:54321 IpLen:20 DgmLen:84
```

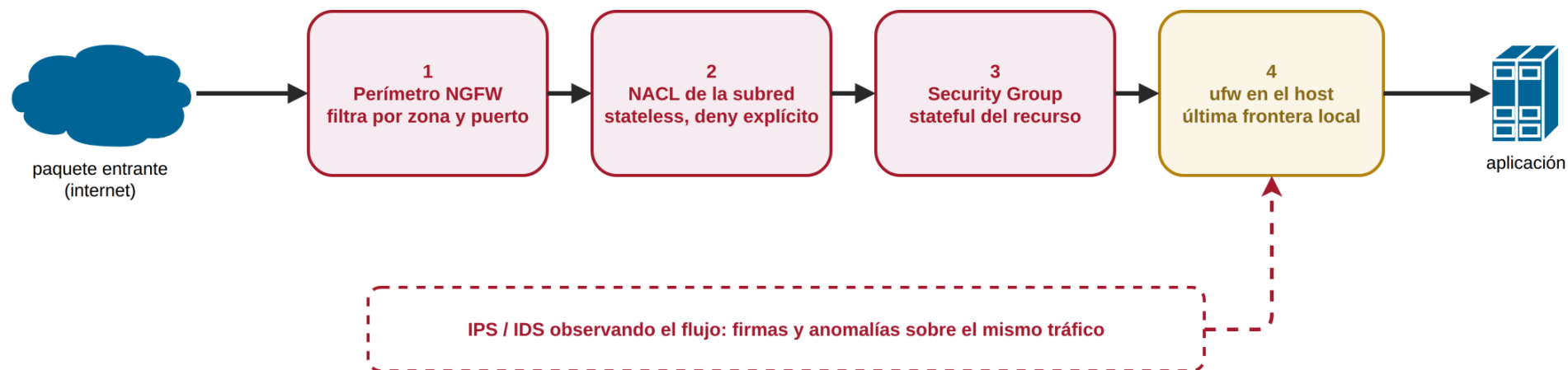
Así se ve una alerta real: clasificación, prioridad, hora, par origen – destino y protocolo — la materia prima del analista.

Dónde vive un IDS/IPS en la red real

- **Modo pasivo (NIDS):** un puerto SPAN del switch o un TAP entrega una *copia* del tráfico — si el sensor falla, la red sigue.
- **Modo en línea (NIPS):** instalado entre el firewall interno y los servidores; cada paquete pasa por él. Riesgo: latencia y bloqueo total si falla → se implementa con **bypass / fail-open**.
- **Ubicación típica:** tras el perímetro, frente a la DMZ y en el core del datacenter — donde convergen los flujos que valen vigilar.
- **Dimensionamiento honesto:** el tráfico efectivamente inspeccionado es mucho menor al nominal; cada regla adicional cuesta CPU.

Decisión de arquitectura: detectar sin tocar el camino (seguro, reactivo) vs. prevenir en línea (poderoso, riesgoso).

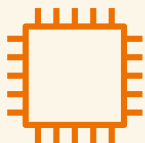
Defensa en profundidad: el recorrido completo



Cada capa asume que la anterior puede fallar: cuatro decisiones independientes antes de tocar la aplicación

Las capas 2 y 3 son **cloud-native** (NACL y Security Group); la 1 y la 4 existen igual en un datacenter tradicional — el modelo no cambia, cambia quién administra cada capa

Security Groups: el mismo control, como servicio



Firewall virtual asociado a cada instancia o interfaz de red en AWS — fuera del sistema operativo, administrado desde consola/API

Mismo modelo mental: reglas allow/deny por protocolo, puerto y origen/destino — lo aprendido con ufw se transfiere directo

Stateful por diseño: permitida la entrada, la respuesta sale automáticamente — igual que el retorno gestionado por conntrack

Nivel de aplicación: se asocia a instancias/ENIs, no a la subred completa (las NACLs son la capa de subred)

Reutilizable: un grupo se aplica a muchas instancias con el mismo rol — web, base de datos, administración

Cuotas vigentes: 60 reglas inbound + 60 outbound por grupo · hasta 5 grupos por interfaz · referenciar **grupo** ↔ **grupo** en vez de CIDR sueltos

1

Lanzar la instancia con su **Security Group**
solo 22 desde la red del taller y
80/443 abiertos

2

Aplicar **ufw dentro del host**
misma política en segunda capa

3

Verificar con **nmap** desde otra
instancia
open vs filtered según la capa que
filtra

4

Documentar reglas y resultados
evidencia para la actividad

La experiencia clave del laboratorio: **dos capas de filtrado independientes** sobre el mismo servidor — y saber decir cuál capa bloqueó cada paquete observado con nmap.

Evaluación: Actividad 2 — 10% · AWS Academy Cloud Security Foundations, Lab 4.1. Fuentes: Ubuntu UFW wiki · DigitalOcean · Nmap.org · documentación AWS VPC Security Groups.